

Indicadores y Métricas de Ciberseguridad en el Marco COSO: Tendencias 2025-2026 con Aplicación a España y Perspectiva Mundial

"Medir lo que no duele no sirve para curar lo que sí duele."

— Paráfrasis libre del principio de relevancia en gestión de riesgos

Resumen Ejecutivo

El Committee of Sponsoring Organizations of the Treadway Commission (COSO) ha consolidado, entre 2025 y 2026, un ecosistema de tres marcos complementarios —el Internal Control–Integrated Framework (IC 2013), el Enterprise Risk Management–Integrating with Strategy and Performance (ERM 2017) y el recién publicado Corporate Governance: Guiding Principles for Board Oversight (CGF, 31 de marzo de 2026, desarrollado con PwC)— que, juntos, articulan el ciclo completo de gobierno, riesgo y control desde la sala de máquinas operativa hasta la sala de juntas. En ese mismo período, España registró 122.223 incidentes de ciberseguridad en 2025 —un 26% más que en 2024—, convirtiéndose en la cifra más alta jamás registrada por INCIBE, mientras el Centro Criptológico Nacional gestionó más de 200.000 incidentes y contabilizó 278 eventos críticos, el 293% más que el año anterior. Este informe examina, con exhaustividad y sin límite de palabras, cómo los indicadores y métricas de ciberseguridad propuestos o asumidos dentro del marco COSO evolucionan para hacer frente a un paisaje de amenazas que ya no admite respuestas estáticas.^{[1][2][3][4][5][6]}

1. El Marco COSO en 2025-2026: Estado del Arte y Evoluciones Recientes

1.1 La Trilogía COSO: IC, ERM y el Nuevo CGF

COSO opera históricamente sobre dos pilares doctrinales:

- IC–Integrated Framework (2013): cinco componentes interdependientes —Entorno de Control, Evaluación del Riesgo, Actividades de Control, Información y Comunicación, y Actividades de Monitoreo— articulados en 17 principios orientados al control interno, la integridad del reporte financiero y el cumplimiento.^{[7][8]}
- ERM–Integrating with Strategy and Performance (2017): cinco componentes y 20 principios que reencuadran la gestión del riesgo como habilitador estratégico, integrándola directamente en la creación de valor y la gestión del desempeño organizacional.^{[9][10]}

El 31 de marzo de 2026, COSO publicó —en colaboración con PwC— el *Corporate Governance: Guiding Principles for Board Oversight*, doce principios de gobernanza que cierran el círculo entre el gobierno corporativo del consejo y los marcos de control y riesgo preexistentes. Para los practicantes de ciberseguridad, el **Principio 8: Tecnología y Datos** resulta especialmente señero: el consejo debe supervisar las prácticas y oportunidades en materia de tecnología y datos para asegurar su alineación con la estrategia y el apetito de riesgo, abarcando explícitamente las amenazas de ciberseguridad, la privacidad de datos, las interrupciones de servicio, los fallos de terceros y las consecuencias no deseadas de tecnologías avanzadas como la IA.^{[4][5][6]}

Este arco evolutivo no es accidental: refleja la comprensión de que los marcos de control y riesgo, concebidos en la era del papel y la auditoría financiera, deben absorber la textura digital del riesgo contemporáneo sin perder su coherencia sistémica.

1.2 Por Qué COSO ERM Sigue Siendo el Backbone del Riesgo Digital

Según datos de KPMG de 2025, apenas el 64% de las organizaciones ha integrado el riesgo y la resiliencia en su estrategia empresarial. Esta brecha estructural —que no ha desaparecido pese a una década de transformación digital— explica por qué COSO ERM, con su énfasis en la integración estratégica del riesgo y en la creación de valor bajo incertidumbre, sigue siendo el *backbone* de gobernanza elegido para superponer encima los marcos operativos de ciberseguridad.^{[11][12][13]}

La arquitectura resultante, ya documentada en publicaciones académicas de 2025, funciona así:^[11]

- COSO ERM actúa como estructura primaria de toda la arquitectura de riesgo.
- Three Lines of Defense (3LoD) asegura la rendición de cuentas en cada nivel organizacional.
- NIST CSF 2.0 —con sus seis funciones: Govern, Identify, Protect, Detect, Respond, Recover— provee la capa operativa de ciberseguridad que se mapea sobre los principios COSO.

Este enfoque multicapa garantiza que los riesgos estratégicos de alto nivel puedan traducirse en acciones operativas medibles.^[11]

2. Los 20 Principios COSO ERM y su Aplicación a la Ciberseguridad: Mapeo Detallado de Indicadores

El ERM 2017 estructura sus 20 principios en cinco componentes. A continuación se mapea, principio a principio, la aplicación específica a ciberseguridad y los indicadores asociados de mayor relevancia post-2025.^{[13][14][9]}

2.1 Componente I: Gobernanza y Cultura (Principios 1–5)

Este componente establece el "tono desde la cúspide" que condiciona toda la arquitectura de riesgo. En el ámbito ciber, el consejo y la alta dirección no pueden delegar lo que no comprenden.

Principio	Aplicación Ciber	Indicadores/Métricas Clave
P1: El consejo ejerce supervisión del riesgo	Revisión periódica del perfil de ciberriesgo; aprobación del apetito ciber ^[14]	Frecuencia de revisiones de ciberriesgo en el consejo (mínimo mensual en organizaciones maduras: 41% lo hacen según Deloitte 2025 ^[15]); porcentaje de consejeros con formación certificada en ciberseguridad
P2: Establece estructuras operativas	Definición de responsabilidades del CISO; líneas de reporte al consejo o al comité de riesgos ^[15]	Existencia de comité de ciberriesgo documentado; tiempo medio de escalado de incidentes críticos al consejo
P3: Define cultura deseada	Cultura de ciberconcienciación; ética digital	% de empleados que completan formación anual en ciberseguridad; tasa de reporte voluntario de incidentes internos
P4: Demuestra compromiso con valores fundamentales	Políticas de uso aceptable, ética en IA, gestión de identidad	Índice de cumplimiento de políticas de uso aceptable; número de infracciones de política documentadas por trimestre
P5: Atrae, desarrolla y retiene talento	Brecha de talento ciber; retención del CISO y el equipo SOC ^[16]	Tasa de vacantes en roles de ciberseguridad sobre total del equipo; tiempo medio de cobertura de posiciones críticas; índice de rotación del equipo ciber (el 71% de organizaciones europeas tiene dificultades para retener talento ^[17])

Tendencia 2025-2026: El modelo emergente para 2026 sitúa al CISO reportando directamente al CEO o al Comité de Riesgo del Consejo, eliminando el conflicto de interés de reportar al CIO. El nuevo CGF de COSO, a través del Principio 8, codifica esta supervisión tecnológica como responsabilidad no delegable del consejo.^[15]^[6]

2.2 Componente II: Estrategia y Establecimiento de Objetivos (Principios 6-9)

Este componente exige que el riesgo informe la estrategia antes de que la estrategia se ejecute — no al revés. Para la ciberseguridad, esto implica que ninguna iniciativa de transformación digital debería aprobarse sin un análisis previo de su impacto en el perfil de ciberriesgo.

Principio	Aplicación Ciber	Indicadores/Métricas Clave
P6: Analiza el contexto empresarial	Evaluación del ecosistema de amenazas externas; regulación NIS2/DORA/ENS[^18]	Índice de madurez del threat intelligence (cobertura de TTPs del sector); número de fuentes de inteligencia de amenazas integradas; posicionamiento en rankings nacionales/europeos de exposición
P7: Define el apetito de riesgo	Declaración de apetito de ciberriesgo cuantificada; umbrales por tipo de activo[^14]	Pérdida financiera máxima aceptable por incidente (definida en términos ALE/FAIR[^19]); tiempo máximo tolerable de interrupción de sistemas críticos (RTO); tasa máxima aceptable de pérdida de datos (RPO)
P8: Evalúa estrategias alternativas	Análisis ciber de iniciativas de transformación digital, adopción de IA, cloud[^20]	% de proyectos estratégicos con evaluación de riesgo ciber previa; número de estrategias bloqueadas o modificadas por riesgo ciber inaceptable
P9: Formula objetivos de negocio	Objetivos de ciberseguridad alineados con objetivos estratégicos	Número de objetivos estratégicos con KRI de ciberseguridad asociado; % de iniciativas estratégicas con controles ciber embebidos desde el diseño

Apetito de Riesgo Cuantificado — El Salto Cualitativo 2025: La guía COSO "Managing Cyber Risk in a Digital Age" (elaborada con Deloitte) recomienda explícitamente el modelo **FAIR (Factor Analysis of Information Risk)** para cuantificar el riesgo y establecer la tolerancia al riesgo. Este enfoque, adoptado ya por el 45% de organizaciones maduras según el FAIR Institute en 2025, traduce el ciberriesgo en términos financieros —Pérdida Esperada Anualizada (ALE), Frecuencia de Eventos de Pérdida (LEF), Magnitud de la Pérdida (LM)— permitiendo que el consejo tome decisiones con la misma base analítica que aplica a los riesgos financieros o de crédito.[^21][^22][^19][^23][^24]

Las métricas de apetito cuantificado incluyen:[^14]

- Umbrales de impacto financiero: pérdida máxima aceptable por incidente individual; tolerancia anual agregada como porcentaje de ingresos.
- Límites de disrupción operativa: tiempo máximo de inactividad para procesos críticos; objetivos de tiempo de recuperación (RTO) y punto de recuperación (RPO).
- Parámetros regulatorios y reputacionales: niveles de riesgo de cumplimiento aceptables; protocolos de notificación y comunicación ante brechas.

2.3 Componente III: Desempeño (Principios 10-14)

El componente de desempeño es donde la ciberseguridad genera su mayor densidad de indicadores medibles. Representa el corazón operativo del sistema COSO aplicado al ciberriesgo.

Principio	Aplicación Ciber	Indicadores/Métricas Clave
P10: Identifica el riesgo	Inventario de activos críticos; registro de riesgos ciber actualizado en tiempo real ^[^25]	Número de riesgos ciber identificados por trimestre; cobertura del registro de riesgos (% de activos críticos con riesgo evaluado); tiempo medio entre publicación de CVE y registro en el sistema de riesgos
P11: Evalúa la severidad del riesgo	Puntuación de severidad e impacto de amenazas (CVSS, EPSS, FAIR) ^[^26]	Score medio CVSS de vulnerabilidades no parcheadas; tasa de explotabilidad (EPSS >0.5) en el inventario; ALE estimado de los 10 principales riesgos ciber
P12: Prioriza los riesgos	Clasificación de riesgos por impacto en objetivos estratégicos	Porcentaje de riesgos críticos con plan de tratamiento aprobado; ratio de riesgos aceptados/mitigados/transferidos/evitados; score de exposición residual ajustada por negocio
P13: Implementa respuestas al riesgo	Controles técnicos y organizativos; microsegmentación; Zero Trust; MFA ^[^27]	Tasa de cobertura MFA en sistemas críticos; porcentaje de sistemas críticos bajo arquitectura Zero Trust; número de controles implementados vs. planificados por ciclo
P14: Desarrolla una vista de cartera	Perfil de ciberriesgo agregado a nivel empresarial; heat map de riesgos ^[^13]	Índice de riesgo residual ciber a nivel de cartera; exposición financiera total del portafolio de riesgos ciber (expresada en valor monetario); número de riesgos ciber en el umbral del apetito o por encima

Las 7 Métricas Críticas post-2025 para la Función CISO (Principio 10-14):

Investigación publicada en diciembre de 2025 por CiberseguridadEgalicia.gal identifica las métricas más relevantes que toda función CISO debería incorporar en 2026, alineadas con los principios 10-14 del ERM:^[^28]

1.
Time-to-Exploit (TtE): El intervalo entre la divulgación de una vulnerabilidad y su explotación efectiva se redujo en 2025 de plazos cercanos a 90 días a rangos medios de 48-72 horas, y en escenarios de explotación automatizada por debajo de las 6 horas. Esta métrica es directamente relevante para el Principio 10 (identificación de riesgo) y P11 (evaluación de severidad).[^28]
2.
Riesgo Residual Dinámico: Los modelos anuales de riesgo residual resultan insuficientes; el riesgo residual debe recalcularse de forma continua integrando datos de threat intelligence en tiempo real. Aplica directamente a P11 y P12.[^28]
3.
Métricas de Identidad: El número de cuentas privilegiadas con acceso sin MFA, la tasa de cuentas huérfanas activas, y el tiempo medio de revocación de accesos post-baja. La identidad se consolida como el nuevo perímetro.[^29]
4.
Exposición en Cadena de Suministro: Score de riesgo de terceros proveedores críticos; % de proveedores evaluados anualmente; número de dependencias ICT sin evaluación formal. El 37% de organizaciones europeas reporta dificultades en este dominio.[^30][^17][^31]
5.
Exposición a IA Adversarial: Porcentaje del perímetro con capacidad de detección de ataques asistidos por IA; número de escenarios de ataque IA modelizados e incorporados al registro de riesgos.[^32]
6.
KRIs de Continuidad de Negocio: RTO real vs. RTO objetivo por sistema crítico; tasa de éxito de pruebas de recuperación; cobertura de planes de continuidad. El 49% de las organizaciones europeas considera la continuidad de negocio su principal reto de implementación NIS2.[^17][^33][^34][^30]
7.
Métricas de Cumplimiento Regulatorio: Índice de conformidad con ENS, NIS2, DORA e ISO 27001; número de no conformidades abiertas; tiempo medio de cierre de hallazgos de auditoría.[^35]

Time-to-Exploit (TtE): El intervalo entre la divulgación de una vulnerabilidad y su explotación efectiva se redujo en 2025 de plazos cercanos a 90 días a rangos medios de 48-72 horas, y en escenarios de explotación automatizada por debajo de las 6 horas. Esta métrica es directamente relevante para el Principio 10 (identificación de riesgo) y P11 (evaluación de severidad).[^28]

Riesgo Residual Dinámico: Los modelos anuales de riesgo residual resultan insuficientes; el riesgo residual debe recalcularse de forma continua integrando datos de threat intelligence en tiempo real. Aplica directamente a P11 y P12.[^28]

Métricas de Identidad: El número de cuentas privilegiadas con acceso sin MFA, la tasa de cuentas huérfanas activas, y el tiempo medio de revocación de accesos post-baja. La identidad se consolida como el nuevo perímetro.[^29]

Exposición en Cadena de Suministro: Score de riesgo de terceros proveedores críticos; % de proveedores evaluados anualmente; número de dependencias ICT sin evaluación formal. El 37% de organizaciones europeas reporta dificultades en este dominio.[^30][^17][^31]

Exposición a IA Adversarial: Porcentaje del perímetro con capacidad de detección de ataques asistidos por IA; número de escenarios de ataque IA modelizados e incorporados al registro de riesgos.[^32]

KRIs de Continuidad de Negocio: RTO real vs. RTO objetivo por sistema crítico; tasa de éxito de pruebas de recuperación; cobertura de planes de continuidad. El 49% de las organizaciones europeas considera la continuidad de negocio su principal reto de implementación NIS2.[^17][^33][^34][^30]

Métricas de Cumplimiento Regulatorio: Índice de conformidad con ENS, NIS2, DORA e ISO 27001; número de no conformidades abiertas; tiempo medio de cierre de hallazgos de auditoría.[^35]

2.4 Componente IV: Revisión y Revisión (Principios 15-17)

Principio	Aplicación Ciber	Indicadores/Métricas Clave
P15: Evalúa cambios sustanciales	Identificación de cambios tecnológicos y regulatorios que reconfiguran el perfil de riesgo[^13]	Número de revisiones del registro de riesgos ciber disparadas por cambios (nuevas regulaciones, incidentes públicos sectoriales, cambios tecnológicos); tiempo de respuesta de la función de riesgo ante cambios sustanciales
P16: Revisa riesgo y desempeño	Análisis de tendencias KPI/KRI; revisión trimestral de ERM[^13]	Variación trimestral del score de riesgo residual; tasa de cierre de acciones correctivas; porcentaje de KRIs que superan umbrales de alerta amarilla/roja en el período
P17: Persigue mejora del ERM	Madurez del programa ciber; benchmarking externo	Puntuación en escala de madurez ciber (1-5); posicionamiento relativo vs. sector; número de mejoras de proceso implementadas por ciclo; resultado de auditorías independientes

Tendencia destacada: En 2025, el BCI (Business Continuity Institute) reporta que el 45.4% de las organizaciones ya cuenta con un líder de resiliencia que reporta directamente al consejo, y el 65.5% ha incrementado los recursos financieros para BC y resiliencia. Este dato ilustra la transición de "cumplimiento en papel" a "capacidad operativa ejecutable".^[34]

2.5 Componente V: Información, Comunicación y Reporte (Principios 18–20)

Principio	Aplicación Ciber	Indicadores/Métricas Clave
P18: Aprovecha información y tecnología	Plataformas GRC; dashboards de riesgo en tiempo real; automatización de alertas KRI ^[13]	Latencia del dato de riesgo (tiempo entre ocurrencia del evento y actualización del dashboard); porcentaje de KRIs con alerta automática configurada; cobertura de la plataforma GRC sobre el universo total de riesgos ciber
P19: Comunica información de riesgo	Comunicación escalonada al consejo, la dirección y el nivel operativo ^[13]	Frecuencia y calidad del reporte de ciberriesgo al consejo; número de audiencias diferenciadas con reportes adaptados; índice de comprensión del perfil de riesgo ciber entre consejeros (medido por encuesta periódica)
P20: Reporta sobre riesgo, cultura y desempeño	Informe integrado de ciberriesgo al consejo; reporting regulatorio ^[35]	Tiempo medio de preparación del informe de ciberriesgo; porcentaje de incidentes notificados dentro de los plazos regulatorios (NIS2: 24h alerta inicial, 72h informe preliminar, 1 mes informe final ^[36] ^[37]); calidad del reporte según feedback del consejo

3. Los 5 Componentes del IC-Integrated Framework Aplicados a Ciberseguridad

La guía COSO "Managing Cyber Risk in a Digital Age" (COSO-Deloitte, 2020) —la publicación más específica sobre ciberriesgo en el catálogo COSO— aplica los cinco componentes del IC al gobierno del ciberriesgo. Esta guía sigue siendo el documento de referencia, cuya vigencia se ha intensificado a la luz de las amenazas emergentes de 2025.^[38]^[25]

3.1 Entorno de Control — El ADN Cultural de la Ciberseguridad

El entorno de control establece si la ciberseguridad es una prioridad genuina o un ejercicio cosmético. Las preguntas diagnósticas clave son:^[25]

- ¿El consejo comprende el perfil de ciberriesgo de la organización?
- ¿La dirección está informada sobre la evolución de los riesgos ciber?
- ¿Existen políticas formales de ciberseguridad revisadas periódicamente?

Indicadores específicos:

- Índice de cultura ciber (resultado de encuestas de concienciación periódicas)
- Tasa de participación voluntaria en programas de formación ciber
- Número de incidentes reportados internamente (proxy de cultura de reporte)
- % de líderes senior con formación en ciberseguridad certificada[^39]
- Existencia y actividad del comité de ciberseguridad del consejo

3.2 Evaluación del Riesgo — Del Mapa de Calor a la Cuantificación Financiera

La evaluación del riesgo ciber bajo COSO exige:[^25]

- Que la organización y sus partes interesadas críticas hayan evaluado sus objetivos operativos, de reporte y de cumplimiento en relación con el ciberriesgo.
- Que los riesgos ciber se evalúen en términos de probabilidad e impacto, y que la evaluación se actualice de forma continua.

Indicadores y herramientas:

Métrica	Descripción	Frecuencia
Cobertura del registro de riesgos	% de activos críticos con evaluación de riesgo vigente	Continua (actualización en tiempo real para riesgos críticos)
ALE (Annualized Loss Expectancy)	Pérdida esperada anualizada por tipo de riesgo (metodología FAIR)[^23]	Trimestral o ante cambios sustanciales
CVSS/EPSS score medio	Severidad técnica y explotabilidad del inventario de vulnerabilidades[^26]	Semanal
Tasa de riesgo residual dinámico	Diferencia entre riesgo inherente y controlado, revisada en tiempo real[^28]	Continua
Cobertura de threat intelligence	% de TTPs del sector modelizados en el registro de riesgos	Mensual
Evaluaciones de riesgo de terceros	% de proveedores críticos evaluados en el período[^17]	Anual (con revisión continua para proveedores de máxima criticidad)

La evaluación del riesgo de ciberseguridad debería actualizarse de forma continua para reflejar cambios que podrían afectar el despliegue de controles ciber para proteger los sistemas de información más críticos.[^25]

3.3 Actividades de Control — De la Política al Control Técnico

Las actividades de control bajo COSO para ciberseguridad incluyen los controles técnicos, organizativos y procedurales que mitigan los riesgos identificados.^[8]^[7]

Principio 11 del IC —Controles Generales sobre Tecnología— adquiere especial relevancia:

Los controles que garantizan que la infraestructura tecnológica opera de forma eficiente para soportar los objetivos de negocio incluyen: control de acceso a sistemas, gestión de cambios, backup y recuperación, continuidad de negocio, cumplimiento de privacidad de datos y protección contra ciberamenazas.^[8]

Indicadores por dominio de control:

Gestión de Identidad y Acceso (IAM):

- % de cuentas con MFA habilitado (en sistemas críticos: objetivo 100%)
- Número de cuentas privilegiadas sin revisión en >90 días
- Tiempo medio de desprovisioning post-baja de empleado (objetivo <24h)
- Tasa de cumplimiento del principio de mínimo privilegio

Gestión de Vulnerabilidades:

- Tiempo medio de parcheo de vulnerabilidades críticas (CVSS ≥ 9): el 28% de organizaciones europeas tarda más de 3 meses^[17]
- % de sistemas críticos con cobertura de escaneo continuo
- Ratio de vulnerabilidades conocidas explotadas (KEV) sin remediar sobre total

Detección y Respuesta:

- MTTD (Mean Time to Detect): tiempo medio desde inicio del incidente hasta detección
- MTTR (Mean Time to Respond): tiempo medio desde detección hasta contención^[35]
- Tasa de incidentes no detectados por los controles automatizados (proxy de eficacia del SOC)

Resiliencia y Continuidad:

- RTO actual vs. RTO objetivo por sistema crítico
- Tasa de éxito de ejercicios de recuperación ante desastres
- Cobertura de backups verificados (% de datos críticos con backup testado en <30 días)

Seguridad en la Cadena de Suministro:

- Número de proveedores críticos con evaluación de seguridad vigente^[31]
- % de contratos con cláusulas de ciberseguridad y derecho de auditoría
- Score de riesgo medio del ecosistema de terceros

3.4 Información y Comunicación — El Sistema Nervioso de la Gobernanza Ciber

Este componente exige que la organización haya:^[25]

- Identificado los requisitos de información para gestionar el control interno sobre el ciberriesgo.

- Definido los canales de comunicación internos y externos para el funcionamiento del control interno.
- Establecido el protocolo para responder, gestionar y comunicar un evento de ciberriesgo.

Indicadores:

- Existencia de un plan de comunicación de crisis ciber aprobado por el consejo
- Tiempo de activación del protocolo de comunicación ante incidente (objetivo <1h para incidentes críticos)
- Porcentaje de incidentes notificados a autoridades dentro de plazos regulatorios: bajo NIS2, las entidades esenciales deben emitir una alerta temprana en 24 horas, un informe preliminar en 72 horas y un informe final en 1 mes^[36]^[37]
- Calidad y comprensibilidad del reporte de ciberriesgo al consejo (medida por encuesta semestral)
- Existencia de canales de reporte anónimo para incidentes de seguridad

3.5 Actividades de Monitoreo — De la Auditoría Puntual al Monitoreo Continuo

El monitoreo bajo COSO para ciberseguridad exige la selección y desarrollo tanto de evaluaciones continuas como periódicas para verificar si los componentes del control interno, incluidos los controles ciber, están presentes y funcionando correctamente.^[40]^[25]

Indicadores de madurez del monitoreo:

- Porcentaje de controles críticos con monitoreo automatizado continuo
- Cobertura del SIEM (% de sistemas en alcance con logs integrados)
- Tasa de falsos positivos en alertas de seguridad (proxy de calibración del sistema de monitoreo)
- Número de hallazgos de auditoría interna por ciclo vs. hallazgos de auditoría externa (brecha = indicador de calidad del control interno)
- Frecuencia de ejercicios de red team / penetration testing
- Tiempo medio de cierre de hallazgos de control^[41]

4. Indicadores Emergentes 2025-2026: Las Nuevas Fronteras del Ciberriesgo COSO

4.1 Riesgo Cuántico y Criptografía Post-Cuántica

COSO ERM, como marco de gestión de riesgos emergentes (Principio 15), debe incorporar la amenaza cuántica en el horizonte de planificación estratégica. El NIST ha liderado el proceso de estandarización de la criptografía post-cuántica (PQC), identificando los algoritmos criptográficos más utilizados —RSA, DSA, ECDSA y Diffie-Hellman— como vulnerables ante computadoras cuánticas suficientemente potentes. El algoritmo HQC (Hamming Quasi-Cyclic), incluido en el último ciclo de estandarización PQC del NIST, emerge como alternativa robusta a los esquemas de cifrado basados en retículos. La OCDE advirtió en 2025 que las computadoras cuánticas podrían romper los sistemas criptográficos más utilizados, exponiendo datos financieros sensibles e infraestructuras críticas.^[42]^[43]

Indicadores COSO para el riesgo cuántico:

- Inventario de activos con criptografía vulnerable a ataques cuánticos (% del total)
- Porcentaje de tráfico cifrado con algoritmos resistentes a cuántica
- Existencia de plan de migración criptográfica aprobado con hoja de ruta

- Nivel de exposición al ataque "Store Now, Decrypt Later" (valoración de datos con vida útil >10 años cifrados con algoritmos clásicos)[⁴²]

4.2 Riesgo de IA Adversarial y Automatización de Ataques

En 2025, los actores amenazantes aceleran el uso de IA para automatizar ataques, reduciendo el tiempo de explotación a menos de 6 horas en escenarios avanzados. El 39% de las organizaciones ya usa capacidades de IA en sus programas de ciberseguridad, según la encuesta Deloitte Global Future of Cyber.[²⁰][²⁸]

Indicadores COSO para el riesgo de IA adversarial:

- Cobertura de detección de ataques automatizados/asistidos por IA en la arquitectura de seguridad
- Número de escenarios de ataque IA incluidos en el registro de riesgos y modelizados con FAIR
- Porcentaje de ejercicios de red team que incluyen escenarios de ataque asistido por IA
- Inversión en defensas IA como % del presupuesto total de ciberseguridad

4.3 Riesgo de Cadena de Suministro Digital

El ENISA NIS Investments 2025 identifica la cadena de suministro como el segundo mayor riesgo anticipado para los próximos 12 meses, con el 37% de las organizaciones reportando dificultades en su gestión. El 90% implementa controles orientados a proveedores, pero la dependencia de servicios ICT externalizados y MSSPs crea nuevas dependencias sistémicas.[³⁰][¹⁷]

Indicadores COSO para el riesgo de terceros (alineados con P13-P14 ERM):

- Score de riesgo de terceros (media ponderada del ecosistema de proveedores críticos)
- % de proveedores ICT críticos con evaluación de seguridad vigente (<12 meses)
- Número de incidentes originados en la cadena de suministro sobre total de incidentes
- Cobertura de SBOM (Software Bill of Materials) en aplicaciones críticas
- Tiempo medio de notificación de incidentes de seguridad por parte de proveedores

4.4 Riesgo de Identidades No Humanas (NHIs)

Los sistemas automatizados, APIs y dispositivos IoT constituyen una superficie de ataque creciente. En España, el 85% de las botnets identificadas por INCIBE-CERT en 2025 están relacionadas con dispositivos IoT.[⁴⁴][²]

Indicadores:

- Número de identidades no humanas (service accounts, API keys, tokens) sin rotación en >90 días
- Tasa de dispositivos IoT/OT con firmware actualizado y bajo monitoreo activo
- % de identidades no humanas con permisos en exceso (over-privileged)

5. España: Aplicación Territorial y Contexto Nacional

5.1 El Paisaje del Ciberriesgo en España (2025): Datos Críticos

Los datos de 2025 dibujan un mapa de amenazas sin precedentes para España:

- INCIBE-CERT gestionó 122.223 incidentes de ciberseguridad en 2025, un 26% más que los 97.348 de 2024, la cifra más alta registrada.[^2][^1]
- El malware lideró con 55.411 incidentes, incluyendo 392 ataques de ransomware.[^45]
- El fraude online concentró 45.445 casos —4 de cada 10 incidentes—, con el phishing como técnica predominante (25.133 episodios).[^45]
- Se detectaron 237.028 sistemas vulnerables susceptibles de ser explotados.[^2]
- El CCN-CERT gestionó más de 200.000 incidentes, con 278 incidentes críticos (+293% interanual), 128 de ellos de ciberespionaje.[^3]
- España ocupa el 7.º puesto en Europa entre los países más afectados en el período julio 2024-junio 2025, según el Microsoft Digital Defense Report.[^29]
- INCIBE superó las 114.863 consultas atendidas en 2025, indicador de la preocupación social creciente.[^29]
- Los sectores más afectados entre operadores esenciales: banca (34%), transporte (14%), energía (8%), infraestructuras de mercados financieros (7%) y aseguradoras (6%).[^2]

5.2 La Arquitectura Institucional de la Ciberseguridad en España

España opera uno de los marcos de ciberseguridad nacional más articulados de la Unión Europea. La arquitectura institucional incluye:[^46]

CCN-CERT (Centro Criptológico Nacional): dependiente del CNI, es la autoridad nacional de respuesta a incidentes para el sector público y las infraestructuras críticas. Gestiona las Jornadas STIC (en 2025 congregaron a profesionales de 42 países en Madrid) y publica las Guías CCN-STIC que son referencia técnica internacional.[^47][^46]

INCIBE (Instituto Nacional de Ciberseguridad): centro de referencia para ciudadanos y empresas privadas, dependiente del Ministerio para la Transformación Digital. Opera INCIBE-CERT y actúa como Autoridad de Numeración CVE (CNA) a nivel internacional.[^48][^2]

ENS (Esquema Nacional de Seguridad): marco obligatorio para el sector público español, articulado en 7 principios básicos, 15 requisitos mínimos y hasta 73 medidas de seguridad dependiendo de la categorización del sistema. Su implementación se apoya en las herramientas INES (Indicadores del ENS), AMPARO y PILAR.[^49][^46]

Centro Nacional de Ciberseguridad (CNCS): anunciado por el Presidente Sánchez en octubre de 2025 durante ENISE (León), el CNCS estará adscrito a la Presidencia del Gobierno con el objetivo de reforzar la coordinación del sistema nacional de ciberseguridad. El Plan Industrial y Tecnológico para la Seguridad y la Defensa destina **1.157 millones de euros a ciberseguridad**, con más del 80% ya en tramitación.[^50][^51][^52]

5.3 Marco Normativo Aplicable: NIS2, ENS y DORA

NIS2 en España: la directiva europea, vigente desde enero 2023 con transposición obligatoria antes del 17 de octubre de 2024, amplía significativamente el número de entidades obligadas y establece requisitos más estrictos de gestión de riesgos, notificación de incidentes y responsabilidad directa de los órganos de dirección. A abril de 2026, España continúa finalizando su transposición al ordenamiento interno. Según

ENISA, **13 de los 27 Estados Miembros** aún no han transpuesto NIS2 a su legislación nacional.[⁵³]
[³⁶]

ENISA publicó en junio de 2025 las guías técnicas de implementación NIS2, que incluyen un mapeado de cada requisito legal sobre estándares europeos e internacionales, facilitando la comparación y evitando duplicidades para organizaciones ya certificadas bajo ENS o ISO 27001.[³⁷][⁵⁴]

DORA (Digital Operational Resilience Act): en vigor desde enero de 2025 para el sector financiero de la UE, exige resiliencia operativa digital integrada, pruebas periódicas de TLPT (*Threat-Led Penetration Testing*) y una gestión rigurosa del riesgo de terceros TIC.[¹⁸][³³]

5.4 Mapping COSO ERM ↔ ENS ↔ NIS2 para España

Componente COSO ERM	Marco ENS (España)	Marco NIS2/DORA (UE)
Gobernanza y Cultura (P1-P5)	Principios básicos ENS (7): seguridad integral, gestión del riesgo, prevención, respuesta	Art. 20 NIS2: responsabilidad de los órganos de dirección; Art. 21(1): medidas de gobernanza
Estrategia y Objetivos (P6-P9)	Requisito mínimo: Política de seguridad documentada; categorización de sistemas	Art. 21(2)(a): políticas de análisis de riesgos y seguridad SI
Desempeño (P10-P14)	Medidas de seguridad ENS (hasta 73 según categoría); análisis de riesgos periódico	Art. 21(2): requisitos técnicos y organizativos (autenticación, cifrado, gestión de vulnerabilidades, cadena de suministro)
Revisión y Revisión (P15-P17)	Auditoría bienal obligatoria para sistemas de categoría Alta	Art. 23 NIS2: obligación de notificación; Art. 32-33: supervisión y auditoría
Información y Comunicación (P18-P20)	INES: sistema de indicadores del ENS; reporting al CCN	Art. 23 NIS2: alerta temprana 24h, informe preliminar 72h, informe final 1 mes[³⁶]

5.5 La Iniciativa "Cyber-Resilience Improvement Indicators" de España

El Informe de País 2024 de la Década Digital de la UE destaca que España ha puesto en marcha la iniciativa **Cyber-Resilience Improvement Indicators** para prevenir ciberataques, el **programa de fomento de certificaciones SGSI** con ayudas a pymes, el programa **Cibercooperantes** para aumentar la concienciación, y el programa **INCIBE Emprende** para *startups* de ciberseguridad. Esta iniciativa nacional de indicadores es directamente coherente con los principios de monitoreo y reporte del marco COSO.[⁴⁸]

6. Perspectiva Comparada Internacional

6.1 COSO vs. Frameworks Complementarios: Convergencia, no Competencia

El debate sobre qué framework usar ha dado paso, en 2025-2026, a la certeza de que los marcos se complementan y se superponen en capas:[¹²]

Dimensión	COSO ERM	NIST CSF 2.0	ISO 27001:2022	COBIT 2019
Foco primario	Integración estratégica del riesgo	Funciones operativas de ciberseguridad	SGSI: confidencialidad, integridad, disponibilidad	Gobierno de TI y métricas de desempeño
Estructura	5 componentes, 20 principios	6 funciones (GV-ID-PR-DE-RS-RC)	10 cláusulas, 93 controles	Dominios, objetivos de gestión
Énfasis	Estrategia y valor	Operaciones y resiliencia	Compliance y certificación	Procesos y KPIs TI
Aplicación geográfica	Global (predominante en EE.UU.)	Global (referencia en sector público)	Global (estándar internacional)	Global (fuerte en auditoría TI)
Integración ciber	Marco "backbone"	Capa operativa específica de ciber	Sistema de gestión certificable	Procesos de gobierno TI

La práctica de 2025 articula estos marcos así: COSO provee la **arquitectura de gobierno**, NIST CSF 2.0 la **operativa de ciber**, COBIT los **procesos e indicadores de TI** y la ISO 27001 la **certificación y cumplimiento**.^{[12][40]}

6.2 Tendencias Globales en Inversión y Métricas de Ciberseguridad (2025)

El informe **ENISA NIS Investments 2025** —el más representativo a escala europea, con 1.080 organizaciones de los 27 Estados Miembros— revela:^{[55][16]}

- Los presupuestos de ciberseguridad se mantienen estables en una mediana de 1,5 millones de euros, representando aproximadamente el 9% del gasto TI.^[17]
- La inversión pivota de personas a tecnología y servicios externalizados, reflejando una respuesta estructural al déficit de talento.^[16]
- 76% de las organizaciones tienen dificultades para atraer, y 71% para retener, profesionales de ciberseguridad. El déficit total en la UE alcanza 299.000 profesionales cualificados.^{[16][17]}
- El 70% cita el cumplimiento de NIS2/DORA/CRA como principal motor de inversión, aunque los beneficios trascienden el cumplimiento: mejora en gestión de riesgos (41%), detección más rápida (35%) y mejor respuesta (26%).^[17]
- Las principales amenazas anticipadas para 2026: ransomware (55%), ataques a la cadena de suministro (47%) y phishing (35%).^[17]

El Informe Ponemon 2025 (620 practicantes en EE.UU.) reporta que el **71%** de las organizaciones está aumentando sus presupuestos de ciberseguridad, con una media de **24 millones de dólares**. El 67% basa sus decisiones presupuestarias en evaluaciones de riesgos y amenazas (vs. 53% en 2024). El 51% dispone de un CSIRP aplicado consistentemente en toda la empresa.^[56]

El FAIR Institute 2025 State of Cyber Risk Management documenta que casi el **45%** de las organizaciones usa o planea usar el modelo FAIR para cuantificación del ciberriesgo, con una tasa de éxito reportada del **90%** entre los adoptantes.^[21]

6.3 El Nuevo Estándar de Gobernanza Ciber en el Consejo de Administración

La convergencia entre COSO CGF (2026), los Principios del Foro Económico Mundial para la Gobernanza del Ciberriesgo en Juntas, el marco PwC de supervisión del ciberriesgo y el mandato AI-Cyber del TopCISO para 2026 dibuja un estándar emergente de gobernanza ciber en el consejo que incluye:[⁵][⁵⁷][⁵⁸][³²]

- Comité de tecnología/riesgo del consejo con mandato explícito de supervisión de ciberseguridad
- Reporte periódico del CISO al consejo (al menos trimestral para riesgos altos; mensual en organizaciones maduras)[¹⁵]
- Declaración de apetito de ciberriesgo cuantificada y aprobada por el consejo
- Ejercicios de respuesta a incidentes con participación del consejo (tabletop exercises)
- Competencia ciber en la composición del consejo (al menos un miembro con experiencia acreditada)

7. Integración de Métricas: Dashboard COSO-Ciber para España

A continuación se propone un conjunto integrado de métricas de ciberseguridad organizadas por componente COSO, con indicación de su relevancia para el marco regulatorio español (ENS/NIS2) y su nivel de prioridad según el contexto de amenazas 2025:

Cuadro de Mando Integral COSO-Ciber (Propuesta para España)

Componente COSO	Métrica	Umbral de referencia	Marco regulatorio ES	Prioridad 2025-26
Gobernanza y Cultura	% consejeros con formación ciber	>50%	CGF Principio 8 / NIS2 Art.20	Alta
	Frecuencia reporte CISO-Consejo	Mensual (alta madurez)	NIS2 Art.20	Alta
	Índice de cultura ciber (encuesta)	>3.5/5	ENS Principio Seguridad Integral	Media
Estrategia y Objetivos	ALE top 10 riesgos ciber (FAIR)	Definido por apetito de riesgo	NIS2 Art.21 / DORA	Alta
	RTO sistemas críticos vs. objetivo	Desviación <10%	ENS / DORA Art.12	Alta
	% iniciativas digitales con risk assessment ciber previo	>90%	ENS Cat. Alta	Media
Desempeño	Time-to-Exploit (TtE)	Baseline sectorial + alertas KRI	CCN-CERT IOCs	Crítica
	MTTD (Mean Time to Detect)	<24h para críticos	DORA Art.17	Crítica
	MTTR (Mean Time to Respond)	<4h para críticos	NIS2 Art.23 notificación	Crítica
	% vulnerabilidades críticas parcheadas en <7 días	>90%	ENS medida seguridad	Alta
	Score riesgo terceros (media ponderada)	<3/5 (escala de riesgo)	NIS2 Art.21(2) (d) / DORA	Alta
	% cuentas privilegiadas con MFA	100%	ENS medida IAM	Crítica
	% IoT/OT bajo monitoreo activo	>80%	ENS / NIS2	Alta
Revisión y Mejora	Tasa cierre hallazgos auditoría	>80% en <90 días	ENS auditoría bienal	Media
	Resultado madurez ciber (1-5)	>3.0 (medio-alto)	ENS / NIS2 Art.32	Media

	Desviación KRIs ciber sobre umbral	<20% KRIs en zona roja	ERM/KRI interno	Alta
Información y Comunicación	Tiempo notificación incidente (NIS2)	Alerta 24h / Preliminar 72h	NIS2 Art.23	Crítica
	% incidentes notificados en plazo	100%	NIS2 / ENS INCIBE	Crítica
	Latencia del dashboard de riesgo	<1h para eventos críticos	GRC interno	Media

8. Conclusiones y Recomendaciones Estratégicas

8.1 El Imperativo de la Cuantificación

El mayor avance en el uso de indicadores COSO para ciberseguridad en el período 2025-2026 es el movimiento desde métricas cualitativas —"alto, medio, bajo"— hacia métricas cuantitativas expresadas en términos financieros. El modelo FAIR, recomendado explícitamente por COSO y NIST, permite que el ciberriesgo conviva en el mismo lenguaje que el riesgo crediticio, el riesgo operacional o el riesgo de mercado, facilitando la integración genuina en el ERM empresarial.^{[22][19][59][23][28]}

8.2 El Nuevo CGF de COSO como Palanca de Gobernanza

La publicación del *Corporate Governance: Guiding Principles for Board Oversight* (31 de marzo de 2026) completa la trilogía COSO y convierte el Principio 8 —Tecnología y Datos— en una norma de gobernanza para consejos de administración. Para España, este principio es especialmente relevante en el contexto de la creación del Centro Nacional de Ciberseguridad y la revisión del Plan España Digital 2026.^{[51][52][6][5]}

8.3 El Reto Español: De la Reactividad a la Predictividad

El salto del 26% en incidentes gestionados por INCIBE en 2025, los 278 incidentes críticos del CCN-CERT y el posicionamiento de España como 7.º país europeo más afectado demandan una respuesta sistémica que va más allá del parche y la respuesta. El camino hacia una función ciber predictiva —anticipativa, continua y basada en datos— pasa por implementar la arquitectura de indicadores que COSO propone y que el entorno regulatorio europeo (NIS2, DORA, ENS) ya exige.^{[1][3][29]}

8.4 Agenda de Métricas Prioritarias 2026

Para organizaciones que operen en España en sectores esenciales, la agenda de métricas prioritarias debería incluir:

8.
Implementar la cuantificación del ciberriesgo (CRQ) con FAIR, calculando el ALE de los 10 principales riesgos ciber y presentándolo al consejo con la misma regularidad que los indicadores financieros.[²³][²⁴]
9.
Integrar el Time-to-Exploit como KRI primario, estableciendo umbrales de alerta que activen respuesta automática cuando el TtE de vulnerabilidades críticas sea inferior a 72 horas.[²⁸]
10.
Establecer un dashboard de gobernanza ciber que cubra los cinco componentes COSO con métricas en tiempo real, alimentado por la plataforma GRC y accesible al comité de riesgo del consejo.[⁶][¹³]
11.
Formalizar la declaración de apetito de ciberriesgo cuantificada, con umbrales específicos por tipo de activo, regulación aplicable y umbral de tolerancia de pérdida financiera.[⁶⁰][¹⁴]
12.
Pilotar el CNCS como hub de métricas nacionales, aprovechando la capacidad de INCIBE y CCN-CERT para generar indicadores sectoriales que permitan el benchmarking inter-organizacional y la comparación con los datos del ENISA NIS Investments.[⁵⁰][⁵⁵]

Implementar la cuantificación del ciberriesgo (CRQ) con FAIR, calculando el ALE de los 10 principales riesgos ciber y presentándolo al consejo con la misma regularidad que los indicadores financieros.[²³][²⁴]

Integrar el Time-to-Exploit como KRI primario, estableciendo umbrales de alerta que activen respuesta automática cuando el TtE de vulnerabilidades críticas sea inferior a 72 horas.[²⁸]

Establecer un dashboard de gobernanza ciber que cubra los cinco componentes COSO con métricas en tiempo real, alimentado por la plataforma GRC y accesible al comité de riesgo del consejo.[⁶][¹³]

Formalizar la declaración de apetito de ciberriesgo cuantificada, con umbrales específicos por tipo de activo, regulación aplicable y umbral de tolerancia de pérdida financiera.[⁶⁰][¹⁴]

Pilotar el CNCS como hub de métricas nacionales, aprovechando la capacidad de INCIBE y CCN-CERT para generar indicadores sectoriales que permitan el benchmarking inter-organizacional y la comparación con los datos del ENISA NIS Investments.[⁵⁰][⁵⁵]

Este informe ha sido elaborado mediante investigación exhaustiva de fuentes primarias y secundarias de alta calidad, incluyendo documentación oficial de COSO, publicaciones académicas revisadas por pares, informes de organismos gubernamentales (INCIBE, CCN-CERT, ENISA, NIST, La Moncloa) e informes

sectoriales de instituciones de referencia (Deloitte, PwC, FAIR Institute, BCI, Ponemon Institute). Fecha de cierre de investigación: abril de 2026.

References

13.
Balance INCIBE 2025: 122.223 ciberincidentes en España (+26%) - INCIBE gestionó 122.223 ciberincidentes en 2025 (+26%). 55.411 malware, 25.133 phishing, 392 ransomw...
14.
INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - El Instituto Nacional de Ciberseguridad (INCIBE), dependiente del Ministerio para la Transformación ...
15.
Los incidentes críticos en España por ciberespionaje y cibercrimen ... - El Centro Criptológico Nacional del CNI ha gestionado más de 200.000 incidentes de ciberseguridad en...
16.
Corporate governance principles and board oversight - PwC - Explore COSO's corporate governance guiding principles for board oversight and see how PwC helps bo...
17.
Corporate Governance - GuidingPrinciples - COSO.org - Twelve guiding principles offer boards a practical tool for oversight, accountability, and long-term...
18.
COSO releases new Corporate Governance guidance - For practitioners in IT and cybersecurity, Guiding Principle 8: Technology and Data is an important ...
19.
COSO Framework Applied to Cybersecurity Risks | Chapter 16 - Explore how the COSO Internal Control – Integrated Framework applies to cybersecurity, examining key...
20.
Guide to Five Components of Internal Controls - Pathlock - Five Components of Internal Controls around COSOS are : :Control Environment, Risk Assessment, Contr...
21.
COSO's ERM Framework | Enterprise Risk Management Initiative - One of the most widely embraced ERM frameworks is COSO's Enterprise Risk Management – Integrating wi...
22.
6. Example: Coso Erm In... - COSO ERM framework aligns risk with strategy, strengthens governance, and improves performance, comp...

23.
[PDF] Integrating Climate, Digital, and Cyber Risks into Traditional ...
24.
COSO vs NIST vs COBIT | TeamMate - Wolters Kluwer - Explore COSO, COBIT, and NIST CSF, the three core frameworks shaping internal controls, IT governanc...
25.
COSO ERM Framework: 5 Components, 20 Principles, Full Guide - Master the COSO ERM framework with all 5 components, 20 principles, implementation steps, ISO 31000 ...
26.
COSO ERM 2017 Board Risk Oversight Integration with ... - Board-level cybersecurity risk oversight requires integration of COSO ERM 2017 principles with speci...
27.
CISO Role in 2026: Why Cybersecurity Is Moving to the Boardroom - Explore how the CISO role in 2026 is evolving into a board-level leadership position—and why compani...
28.
ENISA 2025 NIS Investments Report: Technology Prioritized as ... - ENISA's 2025 NIS Investments report shows EU organizations shifting cybersecurity strategies from pe...
29.
Enisa NIS Investments 2025 Report | Davide Maniscalco - LinkedIn - European Union Agency for Cybersecurity (ENISA) #NIS Investments 2025 — Key Takeaways on How Cyber P...
30.
Ciberseguridad 2025 en España: amenazas, regulación, casos y ... - El 2025 está definiendo un escenario de ciberamenazas sin precedentes para las empresas españolas: a...
31.
COSO ERM's Cyber Risk Guidance Recommends FAIR - Another milestone for acceptance of cyber risk quantification.
32.
Deloitte Global's Future of Cyber survey - Deloitte Global's Future of Cyber survey shows how organizations around the world are adapting to a ...

33.
2025 State of Cyber Risk Management Report - The FAIR Institute - The 2025 State of Cyber Risk Management Report examines how leading organizations are adapting their...
34.
10 Ways RiskLens Can Help Implement COSO's Cyber Guidance - Cyber risk quantification is now at the core of guidance for using the popular ERM framework
35.
Cuantificación del Ciberriesgo - Conoce cómo la Cuantificación del Ciberriesgo (CRQ) transforma las evaluaciones tradicionales de cib...
36.
[PDF] Cuantificación del Ciberriesgo - Telefónica Tech
37.
Committee of Sponsoring Organizations of the Treadway Commission
38.
Mapping Cyber Risk Approaches: Bridging Quantification and Scoring - The diverse landscape of cyber risk methodologies, ranging from technical scoring systems like CVSS ...
39.
Directiva NIS2: Como verificar el cumplimiento - Camerfirma - Objetivos de la Normativa NIS2 · Establecer requisitos comunes en toda la UE para garantizar un alto...
40.
las siete métricas de riesgo que toda función CISO debería ... - El año 2025 ha puesto de manifiesto que una evaluación inadecuada del riesgo constituye, en sí misma...
41.
El mapa de riesgos en ciberseguridad que deja el 2025 - Computing - El foco se concentra en infraestructuras críticas, con especial presión sobre energía y telecomunica...
42.
[PDF] NIS Investments 2025 - Main report.pdf - ENISA - This edition was informed by a survey of 1 080 professionals representing organisations28 across all...
43.
Value of Enterprise Risk Management Integration and Supply Chain ... - The study concludes that firm resilience helps to enhance supply chain performance through risk mana...

44.

A 2026 Board-Level Governance Framework for Enterprise Security ... - New 20-Page Strategic Report Establishes Non-Negotiable AI-Cyber Governance Standards as Boards Reco...

45.

[PDF] An in-depth analysis of the new Critical Entities Resilience Directive ... - It helps them better anticipate and respond to business continuity risks while also identifying oppo...

46.

From Tick-Box to Practice: The State of Continuity & Resilience in 2025 - The Business Continuity Institute (BCI) today publishes its Continuity & Resilience Report 2025, an ...

47.

Key Cybersecurity KPIs and Metrics to Report to the Boardroom - Learn about the critical boardroom KPIs and metrics that help CISOs effectively communicate cybersec...

48.

Directiva NIS2 en España: todo lo que debes saber - Factorial - La directiva NIS2 es la nueva normativa europea en materia de ciberseguridad que sustituye y amplía ...

49.

EU Cybersecurity ENISA publishes final NIS2 guidance - Bird & Bird - In June 2025, ENISA published the NIS2 technical guidance, which provides detailed advice on mandato...

50.

Managing Cyber Risk - COSO.org - The guidance provides insight into how organizations can leverage the five components and 20 princip...

51.

¿Cómo gestionar riesgos con el modelo COSO? - GRCTools - El Modelo COSO es una referencia obligada para organizaciones que buscan integrar la gestión de ries...

52.

A comprehensive guide to the COSO internal controls framework. - The five components of the COSO internal control framework · 1. Control environment · 2. Risk assess...

53.

Risk management KPIs: How to measure ERM performance in 7 steps - Learn essential risk management KPIs and ERM performance measurement strategies that drive value for...

54.
Industry News 2025 Post Quantum Cryptography A Call to Action - Experts in the field have sounded the alarm, warning enterprises that they must prepare for the era ...
55.
A policymaker's guide to quantum technologies in 2025 - OECD - Quantum computers could break widely used cryptographic systems, exposing financial and sensitive da...
56.
Cybersecurity Risk Mitigation Recommendations for 2024-2025 - 2025 cybersecurity threats include the rise of non-human identities (NHIs), ransomware, insider thre...
57.
INCIBE gestionó más de 122.000 incidentes de ciberseguridad en ... - El Instituto Nacional de Ciberseguridad (INCIBE) gestionó un total de 122.223 incidentes de ciberseg...
58.
[PDF] An Interview with Spain's National Cryptologic Centre (CCN)
59.
así fueron las Jornadas STIC 2025 del CCN-CERT-CNI - YouTube - viral #video #videos
#ciberseguridad #ciberataques #cybersecurity #cibercrimen #cybercrime | El Cent...
60.
[PDF] Spain - España Digital 2026
61.
ENS - CNI - ... CCN pone a disposición de los organismos las Herramientas de Gobernanza de la Ciberseguridad Nac...
62.
Pedro Sánchez announces the creation of the National ... - La Moncloa - Congress and Exhibition Palace, León, 16 October 2025. The President of the Government of Spain, Ped...
63.
Sánchez confirma la creación de un Centro Nacional de ... - Esta iniciativa se une a la ya impulsada desde el Gobierno para revisar la Estrategia Nacional de Ci...
64.
El presidente del Gobierno anuncia la creación del Centro Nacional ... - Pedro Sánchez ha anunciado la creación del Centro Nacional de Ciberseguridad, adscrito a la Presiden...

65.
NIS2 Update: EU Cyber Authority Sets Out Compliance Expectations ... - While ENISA continues to advance NIS2, EU member states' implementation has lagged behind. Despite c...
66.
NIS2 Update: What ENISA's New Guidance Means for You! - In June 2025, the European Union Agency for Cybersecurity (ENISA) released new operational guidance ...
67.
NIS Investments 2025 - ENISA - European Union - ENISA: Every day we experience the Information Society. Interconnected networks touch our everyday l...
68.
2025 Cybersecurity Threat and Risk Management Report - In 2025, 51 percent of respondents say their organizations have a CSIRP that is applied consistently...
69.
Principles for Board Governance of Cyber Risk - This paper is designed as a reference for corporate directors as they set their organization's cyber...
70.
[PDF] Overseeing cyber risk: the board's role - PwC - This report outlines four key areas where boards should take action to support their company in esta...
71.
NIST Recommends FAIR for Integrating Cybersecurity with ... - By Jeff B. Copeland In a new standard, Integrating Cybersecurity and Enterprise Risk Management (ERM...
72.
[PDF] NIST IR 8286r1 initial public draft, Integrating Cybersecurity and ... - This document is intended to help individual organizations within an enterprise improve their cybers...

Balance INCIBE 2025: 122.223 ciberincidentes en España (+26%) - INCIBE gestionó 122.223 ciberincidentes en 2025 (+26%). 55.411 malware, 25.133 phishing, 392 ransomw...

INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - El Instituto Nacional de Ciberseguridad (INCIBE), dependiente del Ministerio para la Transformación ...

Los incidentes críticos en España por ciberespionaje y cibercrimen ... - El Centro Criptológico Nacional del CNI ha gestionado más de 200.000 incidentes de ciberseguridad en...

Corporate governance principles and board oversight - PwC - Explore COSO's corporate governance guiding principles for board oversight and see how PwC helps bo...

Corporate Governance - GuidingPrinciples - COSO.org - Twelve guiding principles offer boards a practical tool for oversight, accountability, and long-term...

COSO releases new Corporate Governance guidance - For practitioners in IT and cybersecurity, Guiding Principle 8: Technology and Data is an important ...

COSO Framework Applied to Cybersecurity Risks | Chapter 16 - Explore how the COSO Internal Control – Integrated Framework applies to cybersecurity, examining key...

Guide to Five Components of Internal Controls - Pathlock - Five Components of Internal Controls around COSOS are : :Control Environment, Risk Assessment, Contr...

COSO's ERM Framework | Enterprise Risk Management Initiative - One of the most widely embraced ERM frameworks is COSO's Enterprise Risk Management – Integrating wi...

6. Example: Coso Erm In... - COSO ERM framework aligns risk with strategy, strengthens governance, and improves performance, comp...

[PDF] Integrating Climate, Digital, and Cyber Risks into Traditional ...

COSO vs NIST vs COBIT | TeamMate - Wolters Kluwer - Explore COSO, COBIT, and NIST CSF, the three core frameworks shaping internal controls, IT governanc...

COSO ERM Framework: 5 Components, 20 Principles, Full Guide - Master the COSO ERM framework with all 5 components, 20 principles, implementation steps, ISO 31000 ...

COSO ERM 2017 Board Risk Oversight Integration with ... - Board-level cybersecurity risk oversight requires integration of COSO ERM 2017 principles with speci...

CISO Role in 2026: Why Cybersecurity Is Moving to the Boardroom - Explore how the CISO role in 2026 is evolving into a board-level leadership position—and why compani...

ENISA 2025 NIS Investments Report: Technology Prioritized as ... - ENISA's 2025 NIS Investments report shows EU organizations shifting cybersecurity strategies from pe...

Enisa NIS Investments 2025 Report | Davide Maniscalco - LinkedIn - European Union Agency for Cybersecurity (ENISA) #NIS Investments 2025 — Key Takeaways on How Cyber P...

Ciberseguridad 2025 en España: amenazas, regulación, casos y ... - El 2025 está definiendo un escenario de ciberamenazas sin precedentes para las empresas españolas: a...

COSO ERM's Cyber Risk Guidance Recommends FAIR - Another milestone for acceptance of cyber risk quantification.

Deloitte Global's Future of Cyber survey - Deloitte Global's Future of Cyber survey shows how organizations around the world are adapting to a ...

2025 State of Cyber Risk Management Report - The FAIR Institute - The 2025 State of Cyber Risk Management Report examines how leading organizations are adapting their...

10 Ways RiskLens Can Help Implement COSO's Cyber Guidance - Cyber risk quantification is now at the core of guidance for using the popular ERM framework

Cuantificación del Ciberriesgo - Conoce cómo la Cuantificación del Ciberriesgo (CRQ) transforma las evaluaciones tradicionales de cib...

[PDF] Cuantificación del Ciberriesgo - Telefónica Tech

Committee of Sponsoring Organizations of the Treadway Commission

Mapping Cyber Risk Approaches: Bridging Quantification and Scoring - The diverse landscape of cyber risk methodologies, ranging from technical scoring systems like CVSS ...

Directiva NIS2: Como verificar el cumplimiento - Camerfirma - Objetivos de la Normativa NIS2 · Establecer requisitos comunes en toda la UE para garantizar un alto...

las siete métricas de riesgo que toda función CISO debería ... - El año 2025 ha puesto de manifiesto que una evaluación inadecuada del riesgo constituye, en sí misma...

El mapa de riesgos en ciberseguridad que deja el 2025 - Computing - El foco se concentra en infraestructuras críticas, con especial presión sobre energía y telecomunica...

[PDF] NIS Investments 2025 - Main report.pdf - ENISA - This edition was informed by a survey of 1 080 professionals representing organisations28 across all...

Value of Enterprise Risk Management Integration and Supply Chain ... - The study concludes that firm resilience helps to enhance supply chain performance through risk mana...

A 2026 Board-Level Governance Framework for Enterprise Security ... - New 20-Page Strategic Report Establishes Non-Negotiable AI-Cyber Governance Standards as Boards Reco...

[PDF] An in-depth analysis of the new Critical Entities Resilience Directive ... - It helps them better anticipate and respond to business continuity risks while also identifying oppo...

From Tick-Box to Practice: The State of Continuity & Resilience in 2025 - The Business Continuity Institute (BCI) today publishes its Continuity & Resilience Report 2025, an ...

Key Cybersecurity KPIs and Metrics to Report to the Boardroom - Learn about the critical boardroom KPIs and metrics that help CISOs effectively communicate cybersec...

Directiva NIS2 en España: todo lo que debes saber - Factorial - La directiva NIS2 es la nueva normativa europea en materia de ciberseguridad que sustituye y amplía ...

EU Cybersecurity ENISA publishes final NIS2 guidance - Bird & Bird - In June 2025, ENISA published the NIS2 technical guidance, which provides detailed advice on mandato...

Managing Cyber Risk - COSO.org - The guidance provides insight into how organizations can leverage the five components and 20 princip...

¿Cómo gestionar riesgos con el modelo COSO? - GRCTools - El Modelo COSO es una referencia obligada para organizaciones que buscan integrar la gestión de ries...

A comprehensive guide to the COSO internal controls framework. - The five components of the COSO internal control framework · 1. Control environment · 2. Risk assess...

Risk management KPIs: How to measure ERM performance in 7 steps - Learn essential risk management KPIs and ERM performance measurement strategies that drive value for...

Industry News 2025 Post Quantum Cryptography A Call to Action - Experts in the field have sounded the alarm, warning enterprises that they must prepare for the era ...

A policymaker's guide to quantum technologies in 2025 - OECD - Quantum computers could break widely used cryptographic systems, exposing financial and sensitive da...

Cybersecurity Risk Mitigation Recommendations for 2024-2025 - 2025 cybersecurity threats include the rise of non-human identities (NHIs), ransomware, insider thre...

INCIBE gestionó más de 122.000 incidentes de ciberseguridad en ... - El Instituto Nacional de Ciberseguridad (INCIBE) gestionó un total de 122.223 incidentes de ciberseg...

[PDF] An Interview with Spain's National Cryptologic Centre (CCN)

así fueron las Jornadas STIC 2025 del CCN-CERT-CNI - YouTube - viral #video #videos #ciberseguridad #ciberataques #cybersecurity #ciberdelito #cybercrime | El Cent...

[PDF] Spain - España Digital 2026

ENS - CNI - ... CCN pone a disposición de los organismos las Herramientas de Gobernanza de la Ciberseguridad Nac...

Pedro Sánchez announces the creation of the National ... - La Moncloa - Congress and Exhibition Palace, León, 16 October 2025. The President of the Government of Spain, Ped...

Sánchez confirma la creación de un Centro Nacional de ... - Esta iniciativa se une a la ya impulsada desde el Gobierno para revisar la Estrategia Nacional de Ci...

El presidente del Gobierno anuncia la creación del Centro Nacional ... - Pedro Sánchez ha anunciado la creación del Centro Nacional de Ciberseguridad, adscrito a la Presiden...

NIS2 Update: EU Cyber Authority Sets Out Compliance Expectations ... - While ENISA continues to advance NIS2, EU member states' implementation has lagged behind. Despite c...

NIS2 Update: What ENISA's New Guidance Means for You! - In June 2025, the European Union Agency for Cybersecurity (ENISA) released new operational guidance ...

NIS Investments 2025 - ENISA - European Union - ENISA: Every day we experience the Information Society. Interconnected networks touch our everyday l...

2025 Cybersecurity Threat and Risk Management Report - In 2025, 51 percent of respondents say their organizations have a CSIRP that is applied consistently...

Principles for Board Governance of Cyber Risk - This paper is designed as a reference for corporate directors as they set their organization's cyber...

[PDF] Overseeing cyber risk: the board's role - PwC - This report outlines four key areas where boards should take action to support their company in esta...

NIST Recommends FAIR for Integrating Cybersecurity with ... - By Jeff B. Copeland In a new standard, Integrating Cybersecurity and Enterprise Risk Management (ERM...

[PDF] NIST IR 8286r1 initial public draft, Integrating Cybersecurity and ... - This document is intended to help individual organizations within an enterprise improve their cybers...